

Task 1 - GitLab Server

VMs/Containers Configuration:

1 / 13

Recents

Quick Start

Amazon Linux

aws

macOS

Mac

Ubuntu

ubuntu

Windows

Microsoft

Red Hat

Red Hat

SUSE Linux

SUSE

Debian

debian

Search

Include AMIs from AWS, Marketplace and the Community

View all AMIs

Amazon Machine Image (AMI)

Ubuntu Server 22.04 LTS (HVM), 55D Volume Type

ami-0e1bed4f06a3b463d (64-bit (x86)) / ami-081cd0c0edff51233 (64-bit (Arm))

Virtualization: hvm ENA enabled: true Root device type: ebs

Free tier eligible

Description

Ubuntu Server 22.04 LTS (HVM),EBS General Purpose (SSD) Volume Type. Support available from Canonical (<http://www.ubuntu.com/cloud/services>).

Canonical, Ubuntu, 22.04, amd64 jammy image

Architecture

64-bit (x86)

AMI ID

ami-0e1bed4f06a3b463d

Username

ubuntu

Verified provider

1 volume(s) - 30 GiB

Free tier: In your first year of opening an AWS account, you get 750 hours per month of t2.micro Instance usage (or t3.micro where t2.micro isn't available) when used with free tier AMIs, 750 hours per month of public IPv4 address usage, 30 GiB of EBS storage, 2 million I/Os, 1 GiB of snapshots, and 100 GB of bandwidth to the Internet.

[Launch instance](#)

 [Preview code](#)

▼ Instance type [Info](#) | [Get advice](#)

Instance type

t2.large

Family: t2 2 vCPU 8 GiB Memory Current generation: true

On-Demand Windows base pricing: 0.1208 USD per Hour On-Demand RHEL base pricing: 0.1216 USD per Hour
On-Demand SUSE base pricing: 0.1928 USD per Hour On-Demand Ubuntu Pro base pricing: 0.0963 USD per Hour
On-Demand Linux base pricing: 0.0928 USD per Hour

Additional costs apply for AMIs with pre-installed software

☑ All generations

Compare instance types

▼

Key pair (login) [Info](#)

You can use a key pair to securely connect to your instance. Ensure that you have access to the selected key pair before you launch the instance.

Key pair name - required

ansible

▼

 [Create new key pair](#)

Network settings

VPC - required | Info
ypc-0149f58737aeb2ee1
172.31.0.0/16
(default)

Subnet | Info
No preference

Auto-assign public IP | Info
Enable

Additional charges apply when outside of free tier allowance

Firewall (security groups) | Info
A security group is a set of firewall rules that control the traffic for your instance. Add rules to allow specific traffic to reach your instance.
☒ Create security group ☐ Select existing security group

Security group name - required
gitlabSecurityGroup

This security group will be added to all network interfaces. The name can't be edited after the security group is created. Max length is 255 characters. Valid characters: a-z, A-Z, 0-9, spaces, and _-/[]@{}+~=.|]S*

Description - required | Info
GitLab security

Inbound Security Group Rules

▼ Security group rule 1 (TCP; 22, 0.0.0.0/0)

Type | Info
ssh

Source type | Info
Anywhere

Protocol | Info
TCP

Source | Info
Add CIDR, prefix list or security group
0.0.0.0/0

Port range | Info
22

Description - optional | Info
e.g. SSH for admin desktop

Remove

▼ Security group rule 2 (TCP; 443, 0.0.0.0/0)

Type | Info
HTTPS

Source type | Info
Anywhere

Protocol | Info
TCP

Source | Info
Add CIDR, prefix list or security group
0.0.0.0/0

Port range | Info
443

Description - optional | Info
e.g. SSH for admin desktop

Remove

▼ Security group rule 3 (TCP; 80, 0.0.0.0/0)

Type | Info
HTTP

Source type | Info
Anywhere

Protocol | Info
TCP

Source | Info
Add CIDR, prefix list or security group
0.0.0.0/0

Port range | Info
80

Description - optional | Info
e.g. SSH for admin desktop

Remove

Rules with source of 0.0.0.0/0 allow all IP addresses to access your instance. We recommend setting security group rules to allow access from known IP addresses only.

Create security group rule

▼

Configure storage

Info

Advanced

1x

30

GiB

gp2

Root volume (Not encrypted)

🕒 Free tier eligible customers can get up to 30 GB of EBS General Purpose (SSD) or Magnetic storage

✕

Add new volume

The selected AMI contains more instance store volumes than the instance allows. Only the first 0 instance store volumes from the AMI will be accessible from the instance

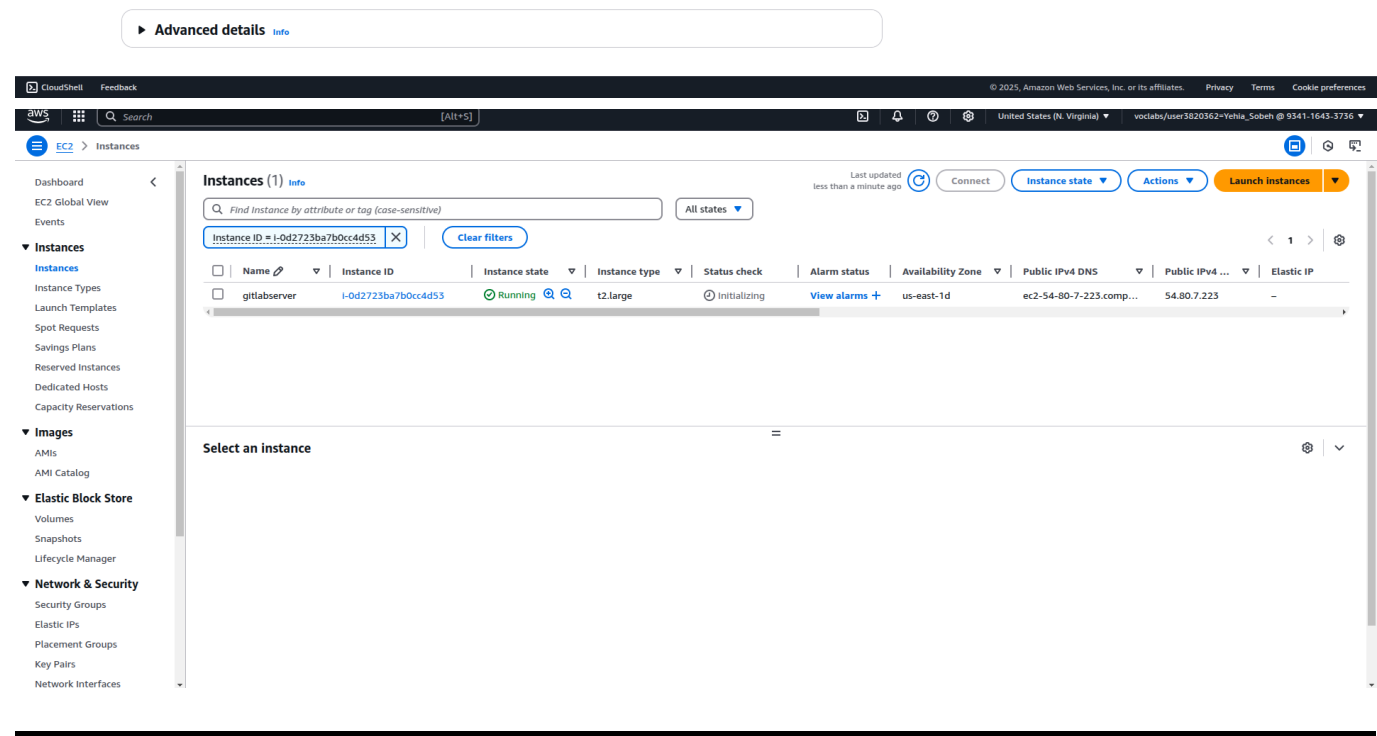
🔄 Click refresh to view backup information

🔄

The tags that you assign determine whether the instance will be backed up by any Data Lifecycle Manager policies.

0 x File systems

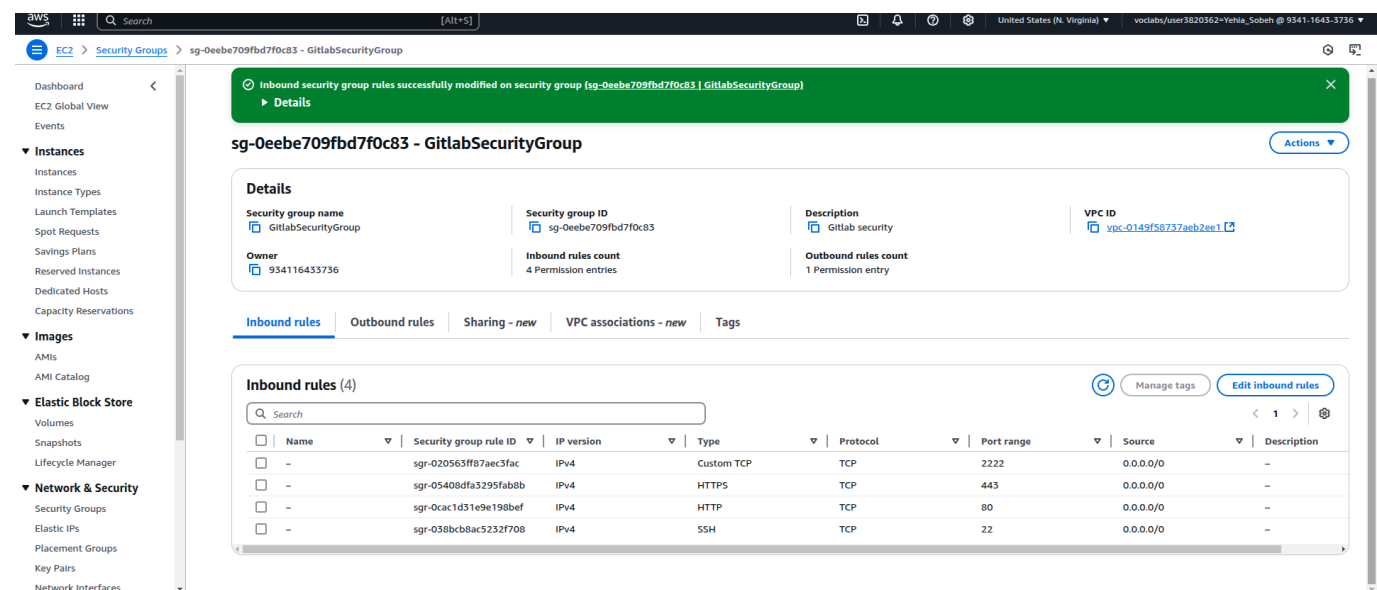
Edit



2. Configuring Security Groups

Updated inbound rules:

- **GitLab Server:**
 - SSH on port 2222
 - HTTP on port 80
 - HTTPS on port 443
- **GitLab Runner:**
 - SSH on port 22
 - HTTP on port 80
 - HTTPS on port 443



3. Installing Docker on GitLab Server

SSH connection and installation commands:

```
ssh -i "gitlab1.pem" ubuntu@ec2-54-157-39-84.compute-1.amazonaws.com

# Add Docker's GPG key
sudo apt-get update
sudo apt-get install ca-certificates curl
sudo install -m 0755 -d /etc/apt/keyrings
sudo curl -fsSL https://download.docker.com/linux/ubuntu/gpg -o
/etc/apt/keyrings/docker.asc
sudo chmod a+r /etc/apt/keyrings/docker.asc

# Add Docker repository
echo "deb [arch=$(dpkg --print-architecture) signed-
by=/etc/apt/keyrings/docker.asc] \
https://download.docker.com/linux/ubuntu $(. /etc/os-release && echo
"${UBUNTU_CODENAME:-$VERSION_CODENAME}") stable" \
| sudo tee /etc/apt/sources.list.d/docker.list > /dev/null
sudo apt-get update

# Install Docker
sudo apt-get install docker-ce docker-ce-cli containerd.io docker-buildx-
plugin docker-compose-plugin
sudo usermod -aG docker $USER
newgrp docker

# Verify
docker -v
docker compose version
```

4. Docker Compose Configuration

docker-compose.yml:

```
version: '3.8'
services:
  gitlab:
    image: gitlab/gitlab-ce:latest
    container_name: yehia-gitlab
    restart: always
    hostname: 'gitlab.test.local'
    environment:
      GITLAB_OMNIBUS_CONFIG: |
        external_url 'https://gitlab.test.local'
        gitlab_rails['gitlab_shell_ssh_port'] = 2222
        nginx['http2_enabled'] = true
        nginx['redirect_http_to_https'] = true
        nginx['ssl_certificate'] = "/etc/gitlab/ssl/gitlab.test.local.crt"
        nginx['ssl_certificate_key'] =
"/etc/gitlab/ssl/gitlab.test.local.key"
```

```
    gitlab_rails['registry_enabled'] = false
    mattermost['enable'] = false
    gitlab_pages['enable'] = false
    gitlab_kas['enable'] = false
    letsencrypt['enable'] = false
  ports:
    - '80:80'
    - '443:443'
    - '2222:22'
  volumes:
    - '/srv/gitlab/config:/etc/gitlab'
    - '/srv/gitlab/logs:/var/log/gitlab'
    - '/srv/gitlab/data:/var/opt/gitlab'
    - '/etc/gitlab/ssl:/etc/gitlab/ssl'
  shm_size: '256m'
```

5. Generating Self-Signed Certificates with mkcert

Steps:

```
mkcert -install
mkcert gitlab.test.local
mv gitlab.test.local.pem gitlab.test.local.crt
mv gitlab.test.local-key.pem gitlab.test.local.key
sudo mkdir -p /etc/gitlab/ssl
sudo cp gitlab.test.local.crt gitlab.test.local.key /etc/gitlab/ssl/
```

6. Updating /etc/hosts

Modified entries:

```
127.0.0.1    localhost
127.0.1.1    yehia-Aspire-A315-58
3.90.40.223  gitlab.test.local
::1         ip6-localhost ip6-loopback
fe00::0     ip6-localnet
ff00::0     ip6-mcastprefix
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters
```

7. Running GitLab Server

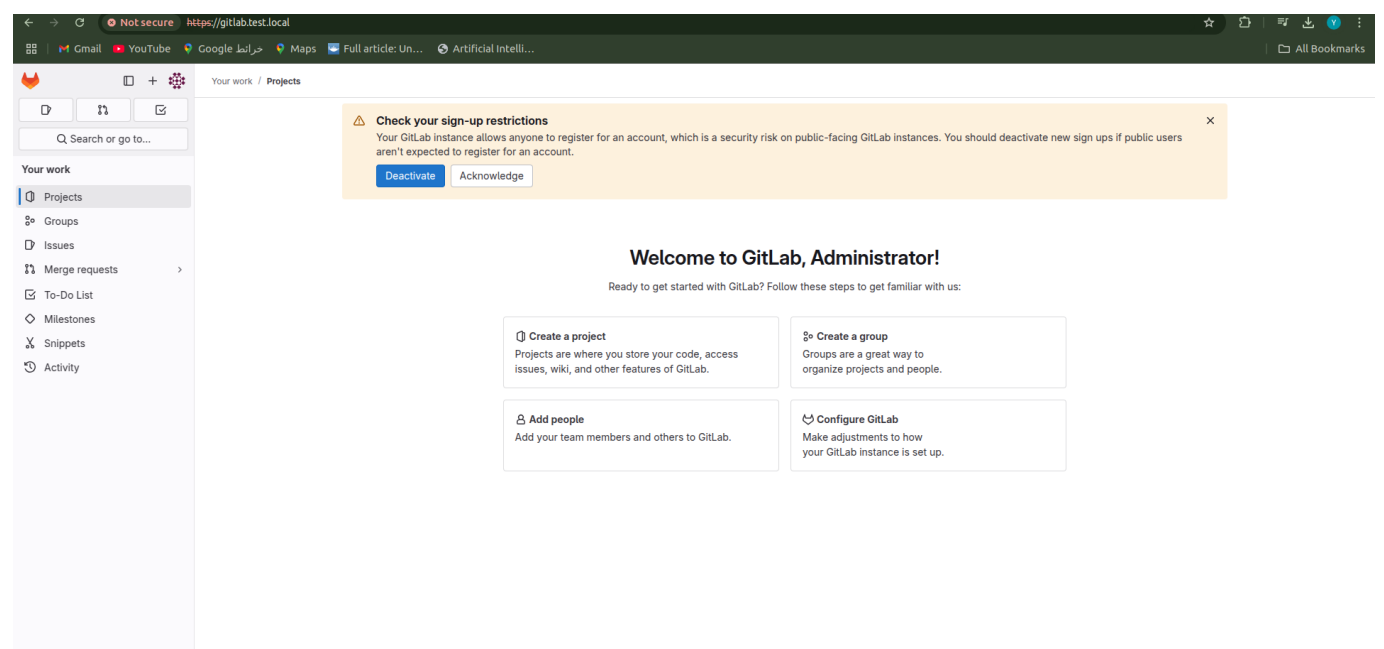
Start container:

```
docker compose up -d
```

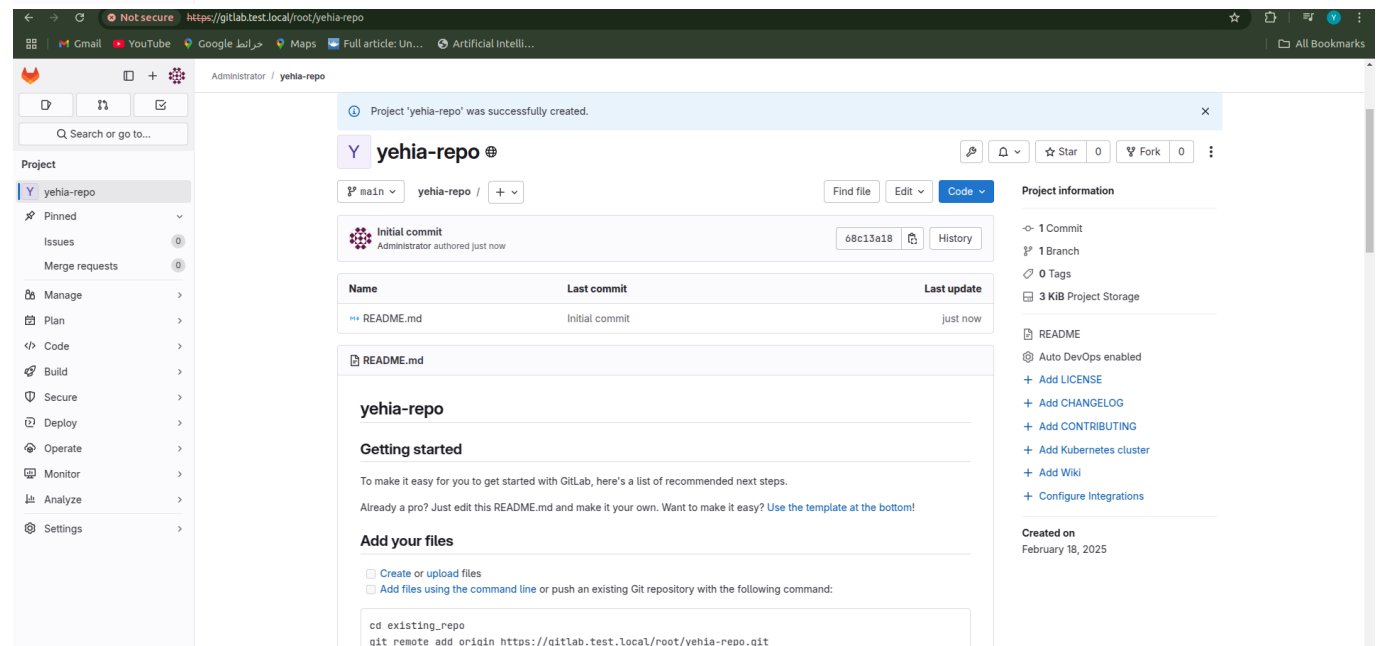
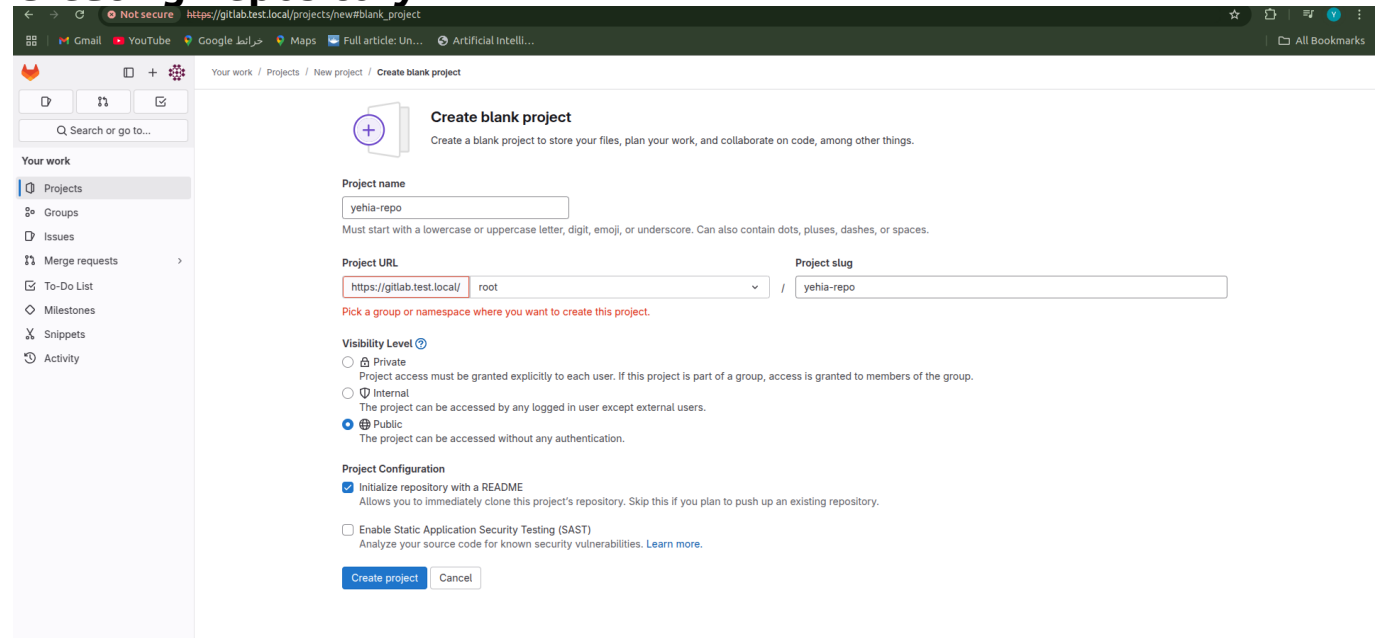
Retrieve root password:

```
docker exec -it yehia-gitlab cat /etc/gitlab/initial_root_password
```





Creating Repository



Task 2 - GitLab Runner

1. Installation & Registration

Install GitLab Runner:

```
curl -L https://packages.gitlab.com/install/repositories/runner/gitlab-  
runner/script.deb.sh | sudo bash  
sudo apt-get install gitlab-runner  
gitlab-runner --version  
sudo systemctl status gitlab-runner
```

Register Runner:

```
gitlab-runner register --url https://gitlab.test.local --token glrt-  
t3_4vJ_REAs8j2TH3vGnX3f  
# Selected executor: shell
```

Start service:

```
gitlab-runner run  
sudo systemctl start gitlab-runner  
sudo systemctl enable gitlab-runner
```

Administrator / yehia-repo / CI/CD Settings / Register runner

Runner created.

Register runner

Platform

Operating systems

☒ Linux ☐ macOS ☐ Windows

Cloud

☐ Google Cloud ☐ GKE

Containers

☒ Docker ☐ Kubernetes

GitLab Runner must be installed before you can register a runner. [How do I install GitLab Runner?](#)

Step 1

Copy and paste the following command into your command line to register the runner.

```
$ gitlab-runner register
--url https://gitlab.test.local
--token glrt-t3_4vJ_REAs8j2TH3v6nX3f
```

The runner authentication token `glrt-t3_4vJ_REAs8j2TH3v6nX3f` displays here for a short time only. After you register the runner, this token is stored in the `config.toml` and cannot be accessed again from the UI.

Step 2

Choose an executor when prompted by the command line. Executors run builds in different environments. [Not sure which one to select?](#)

Step 3 (optional)

Manually verify that the runner is available to pick up jobs.

```
$ gitlab-runner run
```

This may not be needed if you manage your runner as a system or user service.

You've registered a new runner!

Your runner is online and ready to run jobs.

To view the runner, go to **Project > CI/CD Settings > Runners**.

[View runners](#)

You've registered a new runner!

Your runner is online and ready to run jobs.

To view the runner, go to **Project > CI/CD Settings > Runners**.

[View runners](#)

Task 3: Integrating SAST with GitLab CI

1. Cloning DVJA & Repository Setup

```
git clone https://github.com/appsecco/DVJA.git
cd DVJA
rm -rf .git
git init
git add .
git commit -m "Initial commit"
git remote add origin https://gitlab.test.local/root/yehia-repo.git
git branch -M main
git pull --rebase origin main
git add *
```

```
git rebase --continue
git push -u origin main
```

2. .gitlab-ci.yml Configuration

Pipeline file:

```
stages:
  - test

semgrep-sast:
  stage: test
  script:
    - semgrep --config=auto --json > semgrep-report.json
  artifacts:
    paths:
      - semgrep-report.json
  rules:
    - if: $CI_COMMIT_REF_NAME == "main"
```

The screenshot displays the GitLab CI/CD interface for a project named 'yehia-repo'. The left sidebar shows the project navigation menu with 'Jobs' selected. The main panel shows the 'semgrep-sast' job, which failed 11 minutes ago. The job output log shows the following steps:

- Running with gitlab-runner 17.8.3 (690ce25c)
- on gl/t-t3_4vJ_REAs8j2TH3vGnX5F t3_4vJ_RE, system ID: s_8ce94e291odd
- Preparing the "shell" executor
- Using Shell (bash) executor...
- Preparing environment
- Running on ip-172-31-47-20...
- Setting source from Git repository
- Fetching changes with git depth set to 20...
- Reinitialized existing Git repository in /home/ubuntu/builds/t3_4vJ_RE/0/root/yehia-repo/.git/
- Checking out 64291693 as detached HEAD (ref is main)...
- Removing semgrep-report.json
- Skipping Git submodules setup
- Executing "setup_script" stage of the job script
- \$ semgrep --config=auto --json > semgrep-report.json
- bash: line 145: semgrep: command not found
- Cleaning up project directory and file based variables
- ERROR: Job failed: exit status 1

The right sidebar shows the pipeline status: Pipeline #2 Failed for main. It also displays the commit hash 64291693 and the runner information: Runner: #1 (4vJ_REAs).

Post-installation fix:

```
sudo apt install semgrep
echo "Updated pipeline" >> README.md
git add README.md
git commit -m "Triggering CI/CD pipeline"
git push origin main
```

Q Search or go to...

Project

Y yehia-repo

Pinned

Issues

Merge requests

Manage

Plan

Code

Build

Pipelines

Jobs

Pipeline editor

Pipeline schedules

Artifacts

Secure

Deploy

Operate

Monitor

Analyze

Help

Admin

Administrator / yehia-repo / Pipelines / #3

Triggering CI/CD pipeline

Delete

Passed

Administrator created pipeline for commit `10c79716` just now, finished just now

For `main`

latest

 1 job 15 seconds, queued for 1 seconds

Pipeline

Jobs 1

Tests 0

test

semgrep-sast

Q Search or go to...

Project

yehia-repo

Pinned

Issues

Merge requests

Manage

Plan

Code

Build

Pipelines

Jobs

Pipeline editor

Pipeline schedules

Artifacts

Secure

Deploy

Operate

Monitor

Analyze

Settings

semgrep-sast

Passed Started just now by Administrator

Search visible log output

Running with gitlab-runner 17.8.3 (690ce25c)
on glnt-t3-4vj_REAs8j2TH3v6nX3f t3-4vj_RE, system ID: s_8ce9ae2916dd
Preparing the "shell" executor
Using Shell (bash) executor...
Preparing environment
Running on ip-172-31-47-20...
Getting source from Git repository
Fetching changes with git depth set to 20...
Reinitialized existing Git repository in /home/ubuntu/builds/t3-4vj_RE/0/root/yehia-repo/.git/
Checking out 10c79716 as detached HEAD (ref is main)...
Removing semgrep-report.json
Skipping Git submodules setup
Executing "step_script" stage of the job script
\$ semgrep --config:auto --json > semgrep-report.json
/usr/lib/python3/dist-packages/requests/_init_.py:87: RequestsDependencyWarning: urllib3 (2.3.0) or chardet (4.0.0) doesn't match a supported version!
warnings.warn(urllib3 (!) or chardet (!) doesn't match a supported "
METRICS: Using configs from the Registry (like --config=p/ci) reports pseudonymous rule metrics to semgrep.dev.
To disable Registry rule metrics, use "--metrics=off".
Using configs only from local files (like --configs=yml) does not enable metrics.
More information: https://semgrep.dev/docs/metrics

Scan Status

Scanning 176 files tracked by git with 1060 Code rules:

Language	Rules	Files	Origin	Rules
<multilang>	63	174	Community	1060
Java	118	21		
yaml	31	2		
dockerfile	5	1		
json	4	1		
bash	4	1		
html	1	1		

Scan Summary

Some files were skipped or only partially analyzed.
Scan was limited to files tracked by git.
Partially scanned: 1 files only partially analyzed due to parsing or internal Semgrep errors
Scan skipped: 2 files matching .semgreignore patterns
For a full list of skipped files, run semgrep with the --verbose flag.
Ran 222 rules on 174 files: 5 findings.

Uploading artifacts for successful job

Uploading artifacts... archamd64 os:linux pid=5159 revision=690ce25c version=17.8.3

Runtimes platform

semgrep-report.json: found 1 matching artifact files and directories

Uploading artifacts as "archive" to coordinator... 201 Created id=9 responseStatus=201 Created token=gicbt-64

Cleaning up project directory and file based variables

Job succeeded

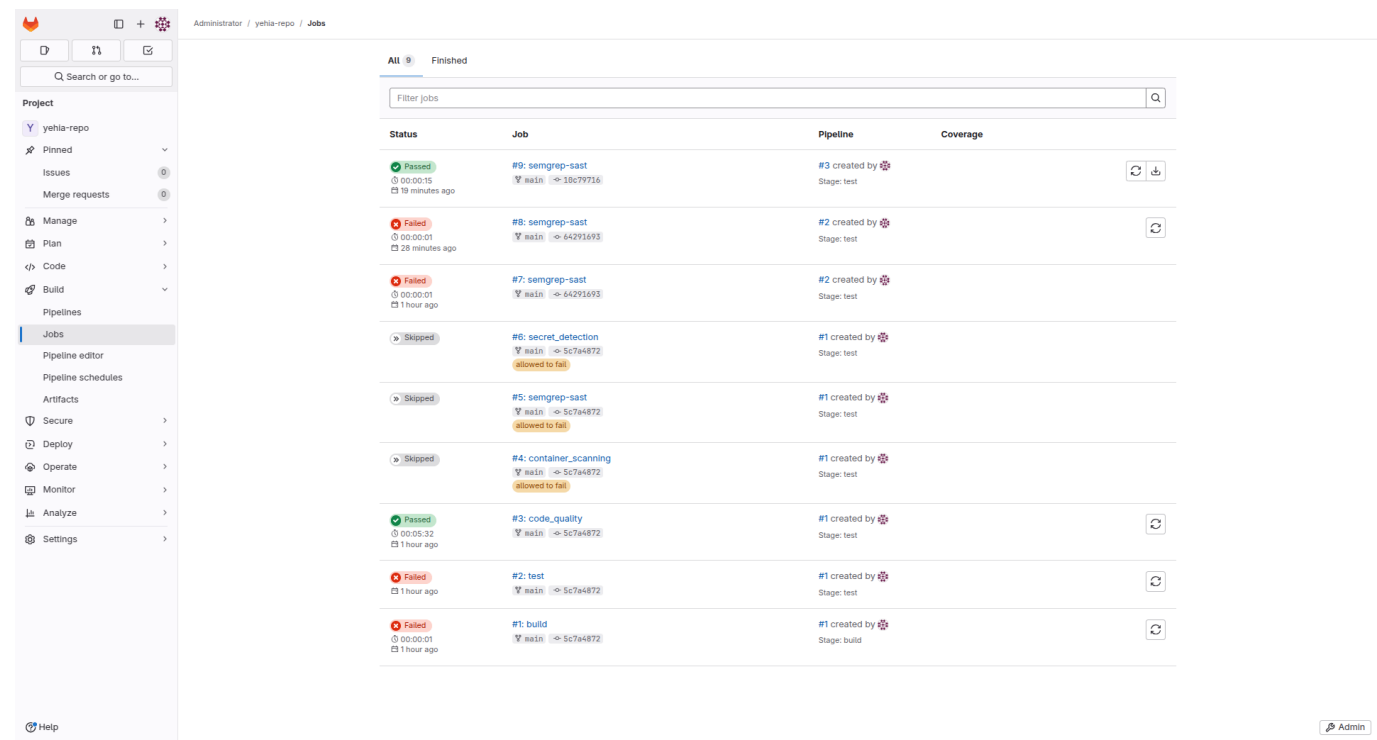
Duration: 15 seconds
Finished: just now
Queued: 0 seconds
Timeout: 1h (from project)
Runner: #1 (4vj_REAs)

Job artifacts
These artifacts are the latest. They will not be deleted (even if expired) until newer artifacts are available.
Keep Download Browse

Commit 10c79716
Triggering CI/CD pipeline

Pipeline #3 Passed for main
test

Related jobs
→ semgrep-sast



3. SAST Report Analysis

After installing the artifacts and make it readable the following result i concluded

Vulnerability	File	Line	Severity	Solution	References
Missing non-root user in Dockerfile	Dockerfile	17	ERROR	Add non-root user: RUN adduser --disabled-password appuser USER appuser	OWASP A04
Privilege escalation risk in Docker Compose	docker-compose.yml	3	WARNING	Add security_opt: no-new-privileges:true	Docker Security Cheat Sheet
Writable root filesystem in Docker Compose	docker-compose.yml	3	WARNING	Set read_only: true	Docker Read-Only FS
SQL Injection	ProductService.java	48	ERROR	Use PreparedStatement: stmt.setString(1, userInput);	OWASP SQL Guide
SQL Injection	UserService.java	75	ERROR	Use PreparedStatement: stmt.setString(1, userInput);	Java Docs
Semgrep Report Syntax Error	semgrep-report.json	1	WARN	Regenerate report or update Semgrep	Semgrep Docs

